iPhone Dealers Hub

A secure web platform where Nigerian iPhone dealers track their stock, trade with one another, and sell to customers through a protected online store.

Project documentation

Author	Muhammad Auwal Abdussamad (M.A Haske)
Brand	Syngle · M.A HASKE TECH HUB, Katsina
Date	November 2026
Live system	https://dealers-hub-5c144.web.app
Source code	github.com/syngle20031/iphone-dealers-hub (private)
Platform	Firebase Hosting, Authentication and Cloud Firestore

Abstract

iPhone dealers in Nigeria run much of their business on trust: phones are handed to other dealers to sell, stock is advertised in WhatsApp groups, and records live in notebooks or memory. Phones go missing, payments are disputed, and customers buying online have no protection against fraud.

This project designed, built and deployed **iPhone Dealers Hub**, a web platform with two parts. The **dealer hub** gives every approved shop a private stock tracker, a record of phones handed between shops that both sides must confirm, a broadcast board, shop ratings and reports, and a middleman service for safe dealer-to-dealer payments. The **customer store** lets the public browse phones listed by verified dealers, filter by state, parts history and Face ID, and order with buyer protection: the customer pays the platform, and the dealer is paid only after the customer confirms the phone is fine.

The system runs on Google Firebase on the free Spark plan. Security is enforced on the server by Cloud Firestore security rules, App Check with reCAPTCHA Fraud Defense, a restricted API key and strict browser security headers, following the OWASP Top 10. Every change pushed to GitHub is deployed automatically by GitHub Actions. The platform is live at dealers-hub-5c144.web.app.

Contents

1. Introduction 3

2. Requirements analysis 5

3. System design 7

Architecture · data model · security design · key processes

4. Implementation 11

Dealer hub · customer store · owner tools · deployment

5. Testing and evaluation 18

6. Conclusion and recommendations 20

Appendix A. User guide 21

Appendix B. Glossary 22

Chapter 1

Introduction

1.1 Background

The used and new iPhone trade is one of the busiest parts of Nigeria's phone market. Dealers in markets such as Farm Centre in Kano, Wuse in Abuja, Bakin Dogo in Kaduna and Computer Village in Lagos buy UK-used, US-used and new phones and resell them to customers and to each other. A large share of sales happen between dealers: one shop gives a phone to another to sell, and the second shop either returns it or pays the agreed price.

Most of this trade is coordinated through WhatsApp messages and memory. A phone's condition, including whether its screen or battery has been replaced, is passed on by word of mouth. Customers who buy online often pay before they see the phone.

1.2 Problem statement

- **Lost track of phones.** When several phones are out with different resellers, dealers lose track of who holds what, what is due back, and who still owes money.
- **Disputes without records.** There is no shared record both sides agreed to, so disagreements about prices, returns and payments are hard to settle.
- **Noisy advertising.** Dealer groups are flooded with repeated posts, so genuine offers and requests get lost.
- **Hidden parts history.** Buyers often discover a replaced screen ("display message") or Face ID fault only after paying.
- **Fraud risk for customers.** Customers buying from unknown sellers online have no protection if the phone never arrives or is not as described.

1.3 Aim and objectives

The aim of the project is to build a secure web platform that brings dealers' daily trade into one trusted system and gives customers a safe place to buy. The objectives were to:

1. Give each approved shop a private tracker for its stock, sales and repairs.
2. Record phones handed between shops as deals that both shops confirm, with a full history.
3. Provide a broadcast board with a fair daily posting limit and a premium tier.
4. Record each phone's parts history (display message status) and Face ID status.
5. Build a public customer store with buyer protection and a fixed platform commission.
6. Protect the platform against common attacks, following the OWASP Top 10.
7. Deploy the system so it runs at no monthly cost and updates automatically.

1.4 Scope

The platform covers the dealer hub, the customer store, owner administration and automatic deployment. Payments are made by bank transfer and confirmed by people in the system; the platform does not move money itself. Optional push and WhatsApp notifications are included as code but are not switched on, because they require Firebase's paid Blaze plan.

1.5 Significance

Dealers gain a reliable record of every phone, which reduces losses and disputes. Customers gain a safer way to buy from verified shops. The platform owner gains a business that earns a commission on store sales and premium memberships.

Chapter 2

Requirements analysis

2.1 Users of the system

User	Role and needs
Platform owner	Runs the platform. Approves shops, switches on premium, handles store payments and middleman deals, reviews reports, and can pause sign-ups, posting or orders during an attack.
Dealer (shop)	Joins with a shop profile and waits for approval. Tracks stock, deals with other shops, posts on the broadcast board, lists phones in the store and fulfils customer orders.
Customer	Browses the store without an account, places an order, pays the platform, receives the phone and confirms it is fine.

2.2 Functional requirements

No.	Requirement	Description
FR1	Shop accounts and approval	Shops sign up with email, password (confirmed twice), shop name, address, city, state and WhatsApp number, then verify their email. Only the owner can approve a shop.
FR2	Private stock tracker	Add, edit and delete phones with model, storage, colour, IMEI, condition, battery, parts, Face ID, price and notes. Record repairs and part changes. Only the shop can see its own stock.
FR3	Deals between shops	Give a phone to another shop or record collecting one. The other shop confirms. Track returns, sales, payments and overdue dates, with a history both shops see.
FR4	Broadcast board	Post selling, looking-for, swap or info messages with photo and TikTok video. Two free posts per day; premium or owner-approved shops post without limit. Comments under posts.
FR5	Customer store	Dealers list phones with a customer price. Customers filter by model, state, condition, parts and Face ID, order without an account, and track the order.
FR6	Buyer protection	The customer pays the platform. The dealer is paid, minus a 5% commission, only after the customer confirms delivery.

FR7	Middleman deals	A dealer can buy from another dealer through the platform, which holds the money until the buyer confirms. Fee: 2%, minimum ₦2,000.
FR8	Trust features	Star ratings and written reviews, reports against shops, "Recently sold" feed (buyers never named), and a "Report a problem" form on every page.
FR9	Owner tools	Approve, suspend and rename shops; set premium; manage orders, middleman deals and reports; edit the Parts and Face ID dropdowns; emergency switches.
FR10	Location	Every shop, listing and order carries one of Nigeria's 36 states or the FCT, and lists can be filtered by state.

2.3 Non-functional requirements

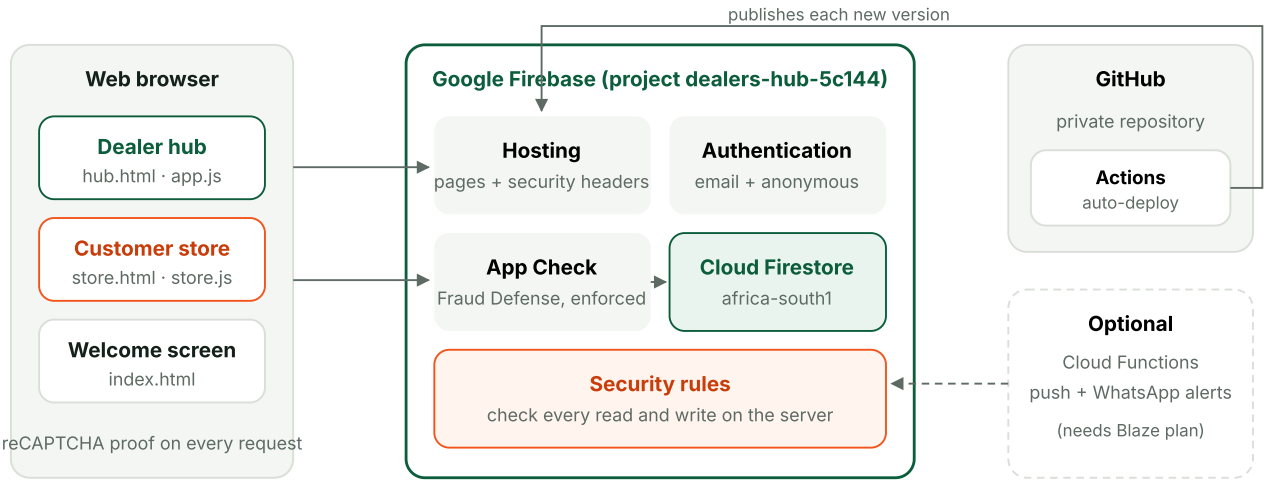
Quality	Requirement
Security	Rules enforced on the server, not only in the app. Personal data visible only to those who need it. Protection against the OWASP Top 10, bots and abuse.
Usability	Built for phones first. Plain English, large touch targets, works for dealers with little technical experience.
Cost	Runs on Firebase's free Spark plan. The store loads phones 40 at a time to keep database reads low.
Availability	Hosted on Google's global network, with HTTPS everywhere.
Maintainability	Source code in GitHub, with every change deployed automatically and a full version history.

Chapter 3

System design

3.1 Architecture

The platform is a set of static web pages served by Firebase Hosting. All data is read and written directly from the browser to Cloud Firestore, and every request is checked by Firestore security rules on Google's servers. There is no separate application server to maintain.



How a request flows

Browser loads pages from Hosting → signs in with Authentication → attaches an App Check proof → reads or writes Firestore → security rules allow or refuse the request. GitHub Actions publishes each new version.

Figure 3.1 — System architecture

3.2 Technology stack

Layer	Technology
Front end	HTML, CSS and plain JavaScript modules, with no framework. Firebase JavaScript SDK 13.2. Installable as a phone app (PWA) with a service worker and manifest.
Hosting	Firebase Hosting with HTTPS, a strict Content Security Policy, HSTS and other security headers set in `firebase.json`.
Sign-in	Firebase Authentication: email and password for dealers (verified email required), anonymous sign-in for store customers.
Database	Cloud Firestore in the africa-south1 region, protected by security rules (about 570 lines).
Bot protection	Firebase App Check with reCAPTCHA Fraud Defense (score-based, invisible), enforced on Firestore.

Source and deployment	Private GitHub repository. A GitHub Actions workflow deploys the site, rules and indexes on every push, using a service account with only the roles it needs.
Optional	Cloud Functions (Node 22) for phone push notifications and WhatsApp alerts. Written and tested but not deployed.

3.3 Data model

Firestore stores data as collections of documents. The main collections are:

Collection	What it holds	Who can read it
`members`	Shop profile: name, address, city, state, WhatsApp, logo, status (pending, active or suspended), premium date.	Approved shops; the shop itself; the owner
`members/{id}/devices`	A shop's private stock: each phone with its details, sale, repairs and history.	That shop only
`moves`	Deals between two shops: owner, holder, phone, agreed price, due date, status, payments and an append-only history.	The two shops in the deal
`posts` + `comments`	Broadcast board posts and their comments.	Approved shops
`listings`	Phones offered in the customer store, with the customer price.	Everyone (live ones only)
`orders` + `private/contact`	Store orders. The customer's name, phone and address sit in a separate private document.	Customer, seller (contact only after payment), owner
`escrows`	Middleman deals between two dealers.	The two dealers and the owner
`ratings`, `reports`, `feedback`	Reviews, reports against shops, and "Report a problem" messages.	Ratings public; reports and feedback owner only
`sales`	The "Recently sold" feed. Buyers are never named.	Everyone
`settings`	Emergency switches and the owner's Parts and Face ID dropdown lists.	Everyone; only the owner can change them
`quota`, `limits`, `custlimits`	Daily counters that stop spam and abuse.	The user they belong to

3.4 Security design

Security was designed in layers, so that no single mistake exposes the platform. The rules are enforced on Google's servers, so changing the app's code in a browser cannot get around them.

Layer	What it does
Firestore security rules	Check identity, ownership, shop approval, field types and sizes on every request. Only the verified owner email has admin powers. Deal histories can only be added to, never edited. Prices, commission and order amounts are checked against the listing, so they cannot be altered.
Abuse limits	Per day: 2 free posts, 150 comments, 10 reports, 30 ratings, 100 deals, 20 middleman deals and 60 sales entries per shop; 5 orders and 5 reports per customer.
Privacy	Customer contact details are stored apart from the order and shown to the seller only after payment. Applicants' details are visible only to the owner until approved.
App Check (enforced)	The database only answers requests that carry a valid reCAPTCHA proof from the real website, which blocks bots and copied settings.
Restricted API key	The Firebase key only works from dealers-hub-5c144.web.app and .firebaseapp.com, and only for the six services the app uses.
Browser security headers	Content Security Policy with no inline scripts, HSTS, X-Frame-Options DENY, nosniff, Referrer-Policy and Permissions-Policy.
Safe output	All text is escaped before display, which prevents cross-site scripting. CSV exports neutralise spreadsheet formulas.
Emergency switches	The owner can pause sign-ups, posting or new orders instantly during an attack.

3.5 Key processes

A deal between two shops

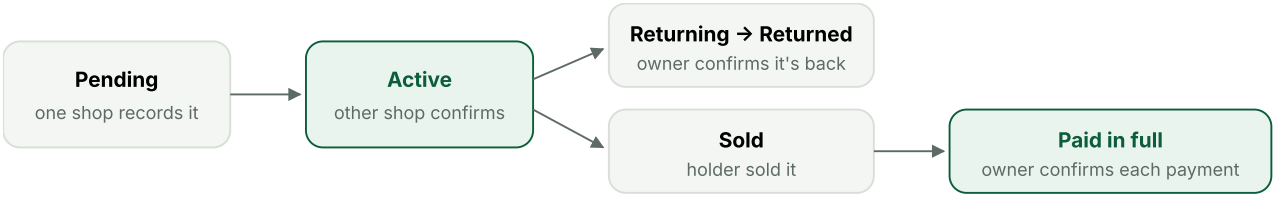


Figure 3.2 — Life of a deal. Each step needs the right shop; the rules refuse anything else.

Every step is written to the deal's history with the shop's name and time, so both sides always see the same record. Overdue deals are highlighted, and a one-tap WhatsApp reminder is

prepared for the late shop.

A customer order with buyer protection

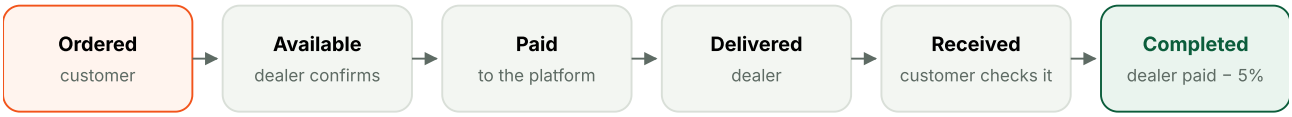


Figure 3.3 — Store order flow. If there is a problem, the customer reports it and the platform refunds them.

Parts history and Face ID

Each phone records two separate checks that buyers care about. **Parts** uses the trade's own terms: *Non display* (all original), *Display screen (DM)* (the screen was changed and the phone shows a display message), and *DDM* (the display, battery or other parts were changed). **Face ID** is recorded as *ID* (working) or *Off ID*. The owner can edit both lists for everyone from the admin tools. Part changes can also be recorded inside a deal, so both shops see when and by whom a part was changed.

Chapter 4

Implementation

This chapter walks through the finished system. The screenshots come from the test version, which runs the same code with sample shops and phones.

4.1 Welcome screen and sign-in

Visitors first choose whether they are a customer or a vendor, and can ask the site to remember the choice. Dealers then log in or apply to join. The join form asks for the shop's details and state, and the password twice with a Show button. A new shop must verify its email and wait for the owner's approval before it can see anything else.

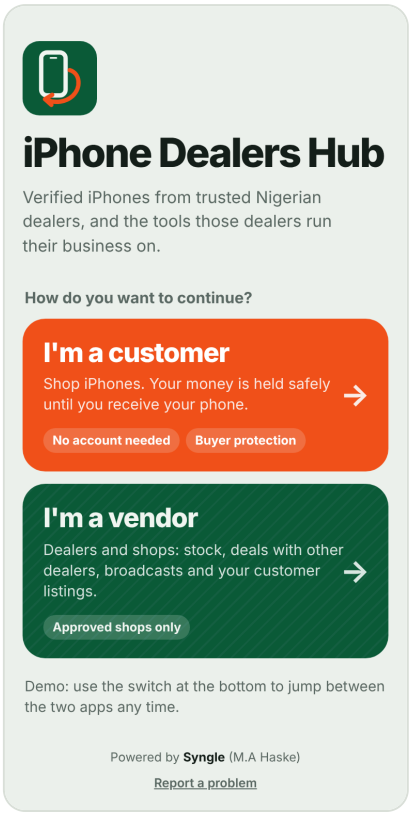


Figure 4.1 — Welcome screen

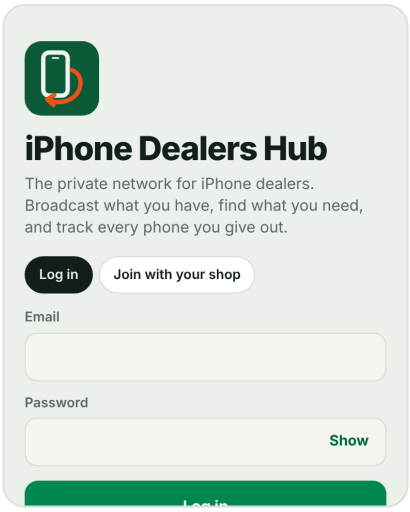


Figure 4.2 — Dealer log-in

4.2 Broadcast board

The board shows posts from all approved shops, filterable by type and state. Free shops get two posts a day; premium shops have a gold badge and unlimited posts. Each post can carry a photo, a TikTok video, parts and Face ID tags, and comments. Owners of a post can mark it sold, and other shops can buy through the middleman.

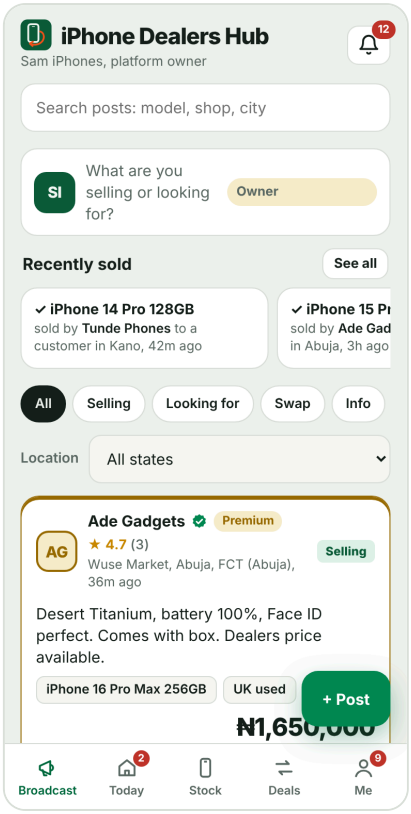


Figure 4.3 — Broadcast board

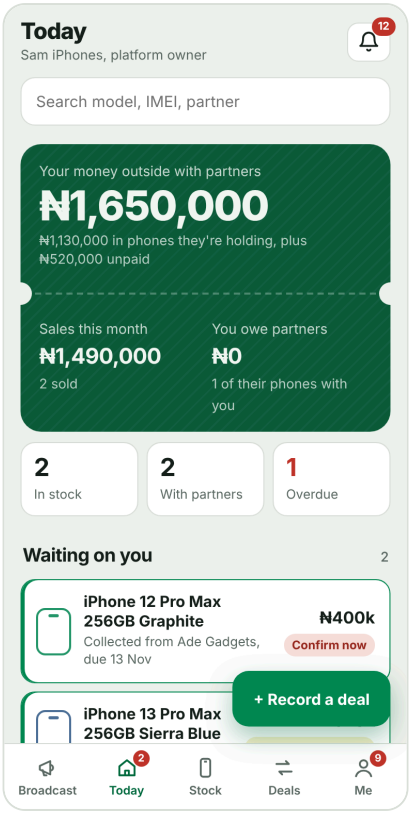


Figure 4.4 — Today: money outside, sales this month, what needs action

4.3 Stock and phone records

Each shop's stock is private. A phone record holds its model (chosen from every iPhone from the 7 to the 18 series), storage, colour, IMEI, condition, battery health, parts, Face ID, price and notes. From a phone, the shop can give it to a partner, record a sale (including a swap phone taken as part payment), broadcast it, list it in the customer store, add a repair cost or record a part change. A WhatsApp receipt is generated for every sale.

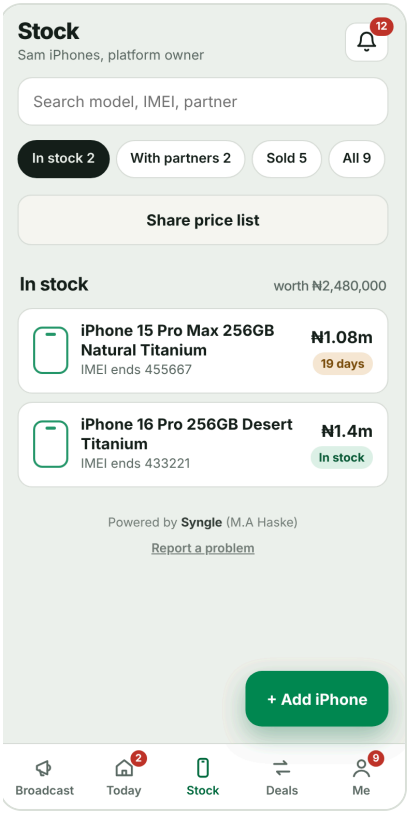


Figure 4.5 — Stock list

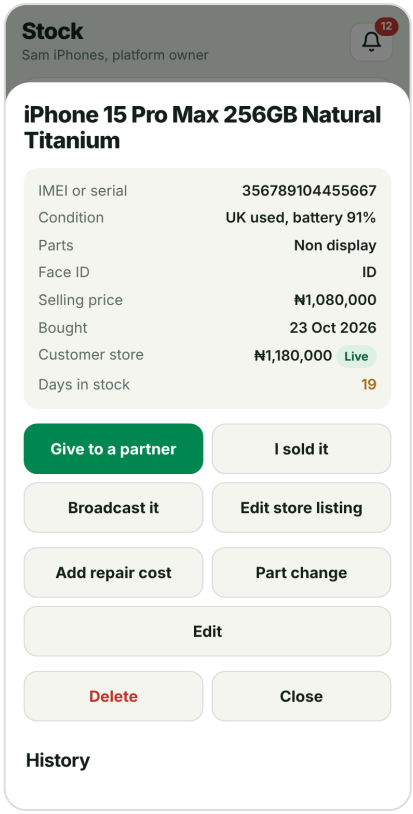


Figure 4.6 — A phone's record and actions

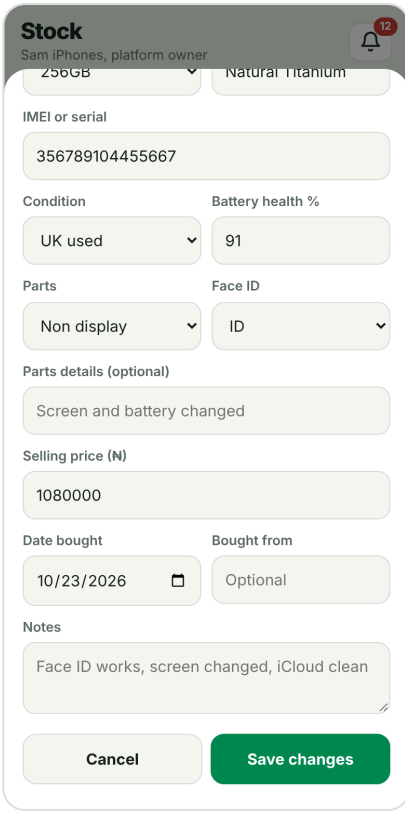


Figure 4.7 — Editing a phone: parts and Face ID

4.4 Deals between shops

The Deals tab lists open, unpaid, overdue and closed deals. Opening a deal shows who owns the phone and who holds it, the agreed price, the due date, the buttons for the next step, and the full history.

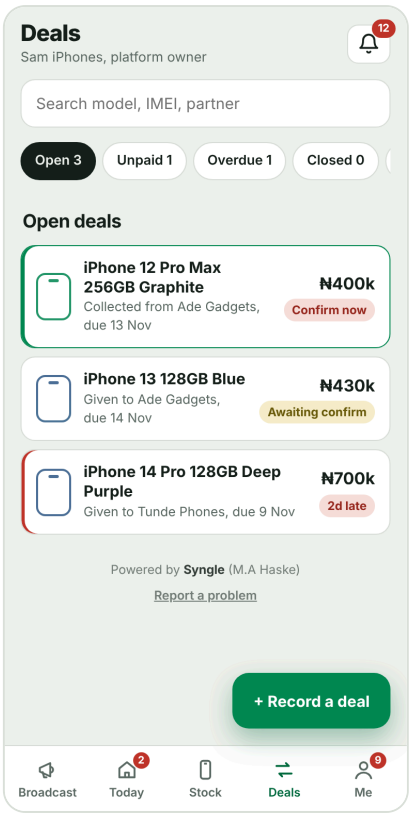


Figure 4.8 — Deals list

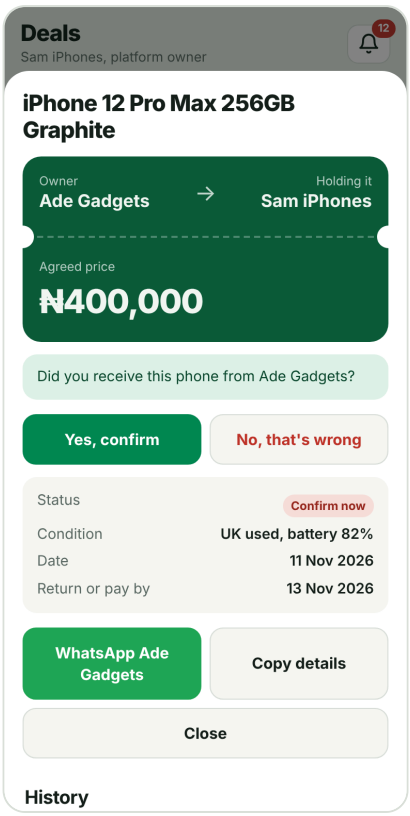


Figure 4.9 — A deal waiting for confirmation

4.5 Customer store

The store shows phones from verified dealers, newest first, 40 at a time. Customers filter by iPhone model, by state, condition and parts in the Filters panel, and by Face ID beside it. Each phone page shows the full specification, parts and Face ID, the seller's rating and location, and the buyer-protection steps. Customers order without creating an account; their contact details are stored privately.

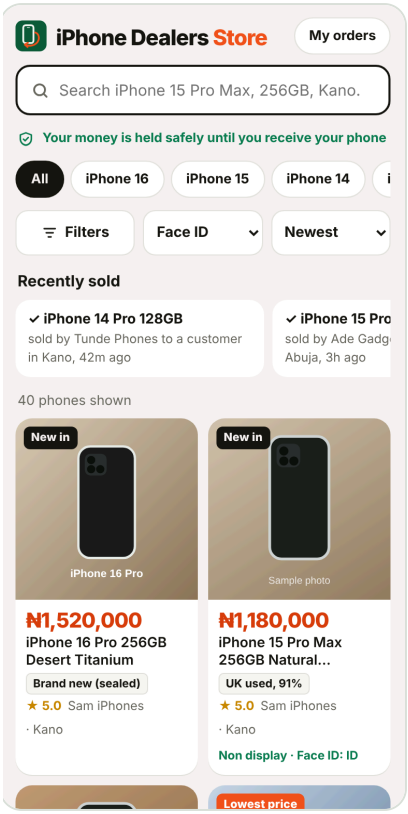


Figure 4.10 — Store home

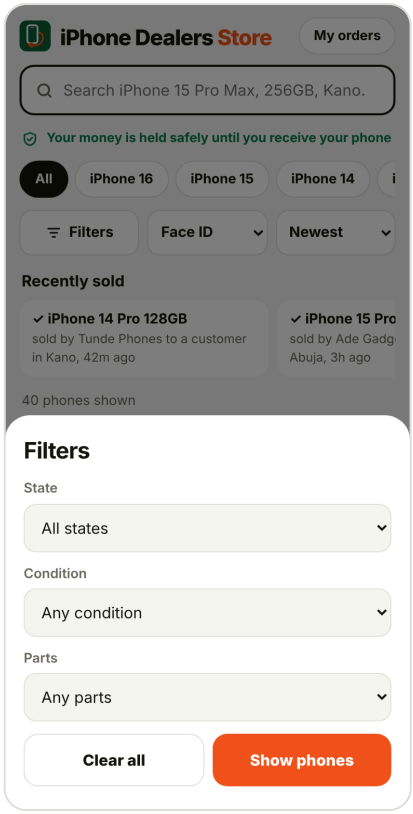


Figure 4.11 — Filters panel

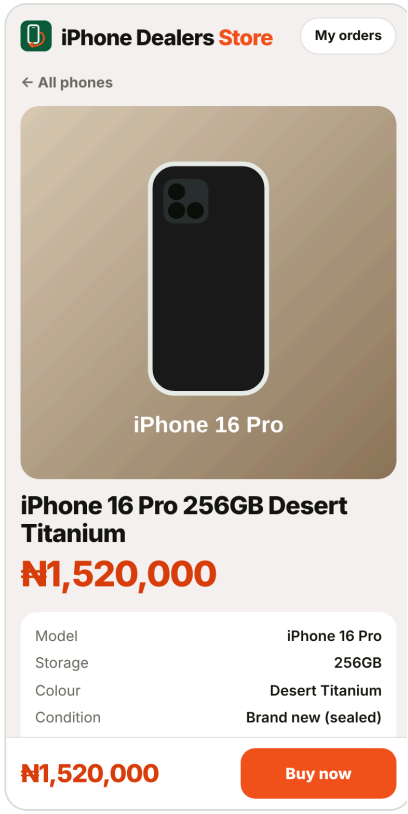


Figure 4.12 — Phone page

4.6 Checkout and owner tools

At checkout the customer gives their name, WhatsApp number, address, city and state. Nothing is paid at this point: the dealer first confirms the phone is available, then the customer receives the payment details.

The owner's **Me** page holds the admin tools: members awaiting approval, Dropdown options, Security switches, vendor reports and the Middleman desk, plus store orders and reports. Reports show sales by month and best-selling models, with CSV export for Excel.

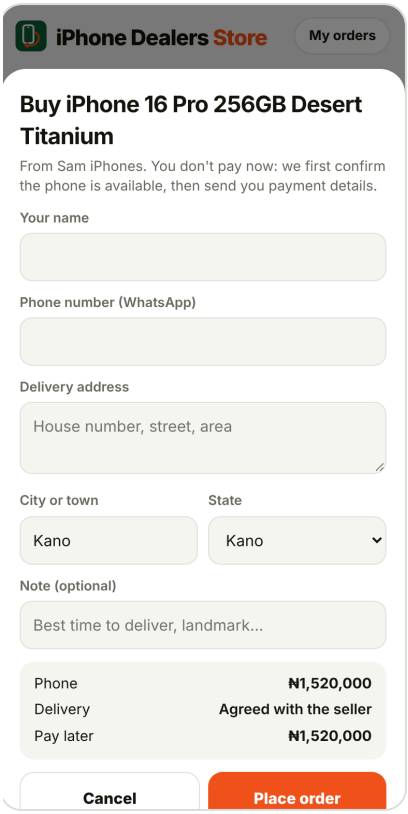


Figure 4.13 — Checkout

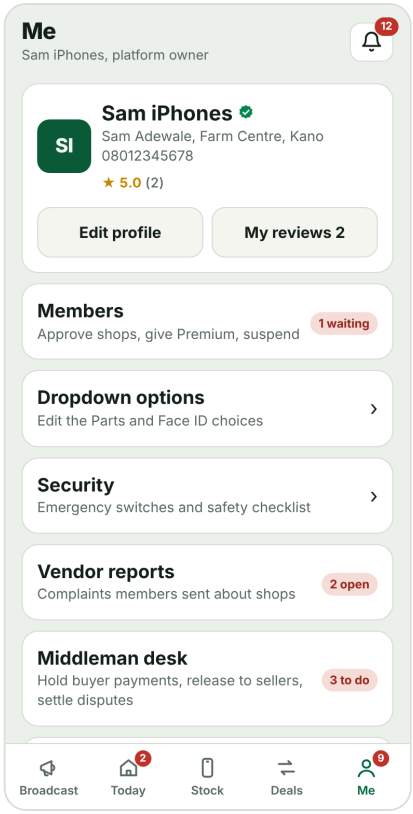


Figure 4.14 — Owner tools

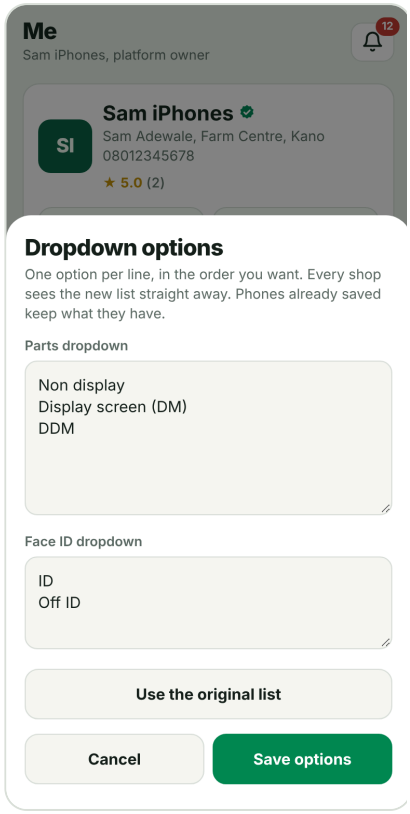


Figure 4.15 — Editing the dropdowns

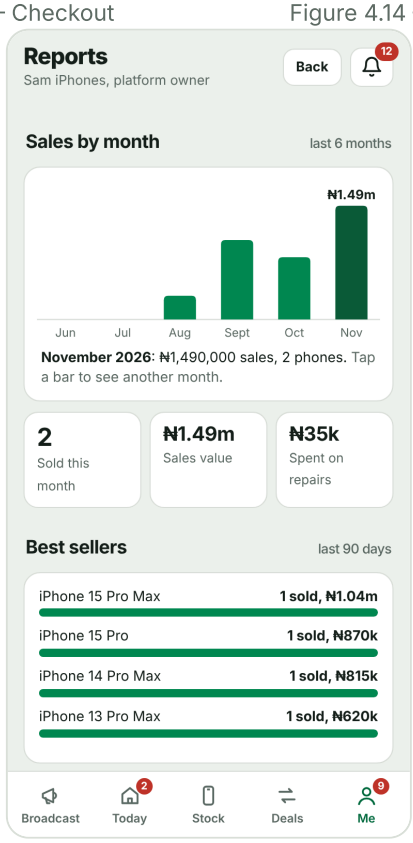


Figure 4.16 — Reports: sales by month

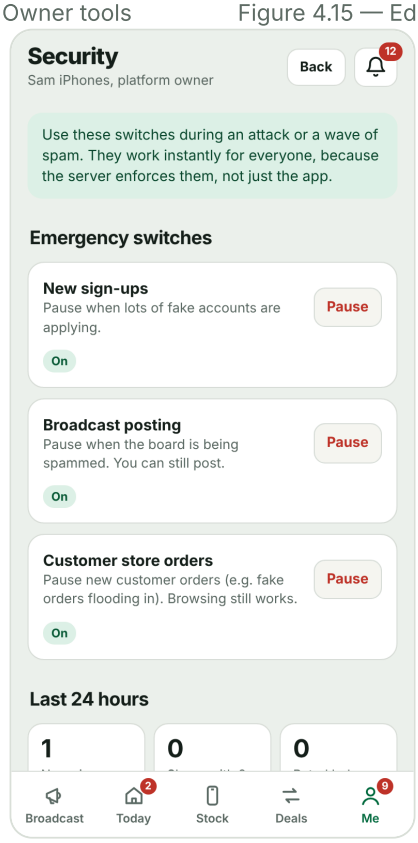


Figure 4.17 — Emergency switches

4.7 Branding and new-shop experience

The platform has its own logo: a phone with an arrow that leaves and comes back, which stands for tracking phones handed out to resellers. Shops can upload their own logo, which appears on their posts, profile and store listings. A new shop sees four clearly marked example items in each empty section, so it understands each page before adding real data. The examples are never saved or shown to anyone else.

4.8 Deployment

The code lives in a private GitHub repository. A GitHub Actions workflow runs on every push to the main branch and deploys the website, security rules and database indexes to Firebase in about a minute:

```
on push to main
  → check out the code
  → sign in to Google Cloud with the github-deployer service account
  → firebase deploy --only hosting,firestore --project dealers-hub-5c144
```

The service account has only the roles needed to deploy: Firebase Hosting Admin, Firebase Rules Admin, Cloud Datastore Index Admin, Cloud Datastore Viewer and Service Usage Consumer. Its key is stored encrypted as a GitHub secret.

Chapter 5

Testing and evaluation

5.1 Approach

Testing used three methods:

- **Scripted end-to-end tests** on the test version. Automated scripts drove real browsers (Chrome through Playwright, and jsdom) through complete journeys as different shops and as a customer, and checked what appeared on screen.
- **Security tests** that tried specific attacks against the code.
- **Live checks** on the deployed site after each security change.

5.2 Functional test results

Area tested	What was checked	Result
Joining and approval	Sign-up with state and matching passwords; mismatched passwords refused; email-verification gate; pending shop sees "Application received".	Passed
Broadcast board	Two-post daily limit and limit message; premium unlimited; comments; filters by type and state.	Passed
Stock and sales	Add, edit, delete phones; repair costs; part changes update the parts line; sale with swap; receipt.	Passed
Deals	Give, collect, confirm, reject, return, sell, part payments, overdue highlighting; history on both sides.	Passed
Customer store	Paging (40 at a time, then "Show more"); filters by model, state, condition, parts and Face ID; full order flow from order to completion with 5% commission.	Passed
Owner tools	Approve and suspend shops; premium; editing dropdown options reaches every shop and the store; emergency switches block posting, sign-ups and orders.	Passed
Examples and logo	Each empty section shows exactly four examples, which disappear after the first real item; logo upload shows on posts.	Passed

5.3 Security test results

Attack attempted	Outcome	Result
Script injection through a crafted deal ID (XSS)	Before the fix, the attack inserted an element into the page. After escaping all IDs, the same attack inserted nothing.	Fixed
Spreadsheet formula injection in CSV export	A phone named `=HYPERLINK(…)` exports as plain text, not a live formula.	Passed
Reading a customer's address before payment	The seller sees "Shown after payment"; the order document itself holds no name, phone or address.	Passed
Requests without App Check proof (live)	Enforcement switched on; the live store and hub still loaded normally with the proof attached.	Passed
Hidden test logins or back doors	The deployed code and rules were searched: no demo accounts, master passwords or bypass switches exist.	Passed

> **Limitation of testing.** The security rules could not be run in Google's Firestore emulator during development, because the build environment had no access to download it. The rules were reviewed line by line and checked for structural errors, and the live site works under them, but formal rule-by-rule emulator tests are recommended (section 6.3).

5.4 Evaluation against the objectives

Objective	Status
1. Private stock tracker for each shop	Met
2. Deals confirmed by both shops, with history	Met
3. Broadcast board with daily limit and premium	Met
4. Parts history and Face ID on every phone	Met
5. Customer store with buyer protection and commission	Met
6. Protection against common attacks (OWASP)	Met, with emulator testing still recommended
7. Free to run, updates automatically	Met: Spark plan, GitHub Actions

Chapter 6

Conclusion and recommendations

6.1 Summary

iPhone Dealers Hub turns the informal, trust-based iPhone trade into a shared, verifiable record. Dealers can see every phone they own and where it is, every deal they have with other shops, and every naira owed. Customers can buy from verified dealers with their money protected until they receive the phone. The platform is live, secured in several layers, costs nothing to run at its current size, and updates itself whenever the code changes.

6.2 Limitations

- Payments are by bank transfer and confirmed by hand; the platform does not process card payments.
- Phone push notifications and WhatsApp alerts are built but switched off, because they need Firebase's paid Blaze plan.
- App Check is not enforced on sign-in, because Firebase's email-confirmation and password-reset pages may not send the App Check proof. The database itself is protected.
- The site uses Firebase's free web address until a custom domain is connected.

6.3 Recommendations and future work

1. **Test the rules in the Firestore emulator**, with automated tests that try every forbidden action.
2. **Add online payments** through a Nigerian payment provider such as Paystack or Flutterwave, so store payments are confirmed automatically.
3. **Turn on notifications** by moving to the Blaze plan when traffic justifies it.
4. **Connect a custom domain**, and add it to the API key and reCAPTCHA allowed sites.
5. **Add IMEI checks** against blacklist services before a phone is listed.
6. **Add a Hausa language option** for dealers in the North.

Appendix A

User guide

For dealers

1. Open dealers-hub-5c144.web.app/hub.html and tap **Join with your shop**.
2. Fill in your shop details and state, confirm your email, and wait for approval.
3. Add your phones in **Stock**.
4. Open a phone to give it to a partner, sell it, broadcast it or list it in the store.
5. Check **Today** every morning for anything overdue or waiting on you.
6. Add your shop logo in **Me → Edit profile**.

For customers

1. Open dealers-hub-5c144.web.app/store.html.
2. Choose a model, then use Filters and Face ID to narrow down.
3. Open a phone and tap **Buy now**.
4. Pay only the account details shown after the dealer confirms.
5. Check the phone when it arrives, then confirm in **My orders**.

For the owner

- **Me → Members:** approve or suspend shops, rename them, set premium.
- **Me → Store orders and Middleman desk:** confirm payments, pay sellers, handle problems.
- **Me → Dropdown options:** edit the Parts and Face ID choices.
- **Me → Security:** pause sign-ups, posting or orders during an attack.
- **Updates:** changes pushed to GitHub go live automatically; see the Actions tab for each deploy.

Appendix B

Glossary

Term	Meaning
Non display	All original parts; the phone shows no parts message.
Display screen (DM)	The screen was replaced and the phone shows a display message.
DDM	The display, battery or other parts were replaced.
ID / Off ID	Face ID works / Face ID does not work.
UK used, US used, Nigerian used	Where a used phone was first used, which affects its value.
Deal	A phone handed from one shop to another, to be returned or paid for.
Middleman	The platform holds the buyer's money until the buyer confirms the phone (escrow).
App Check	A Firebase service that lets the database answer only the real website.
Security rules	Server-side rules that decide who can read or change each piece of data.
OWASP Top 10	The ten most common web application security risks, used as a security checklist.
Spark / Blaze plan	Firebase's free plan / pay-as-you-go plan.

Powered by Syngle (M.A Haske).